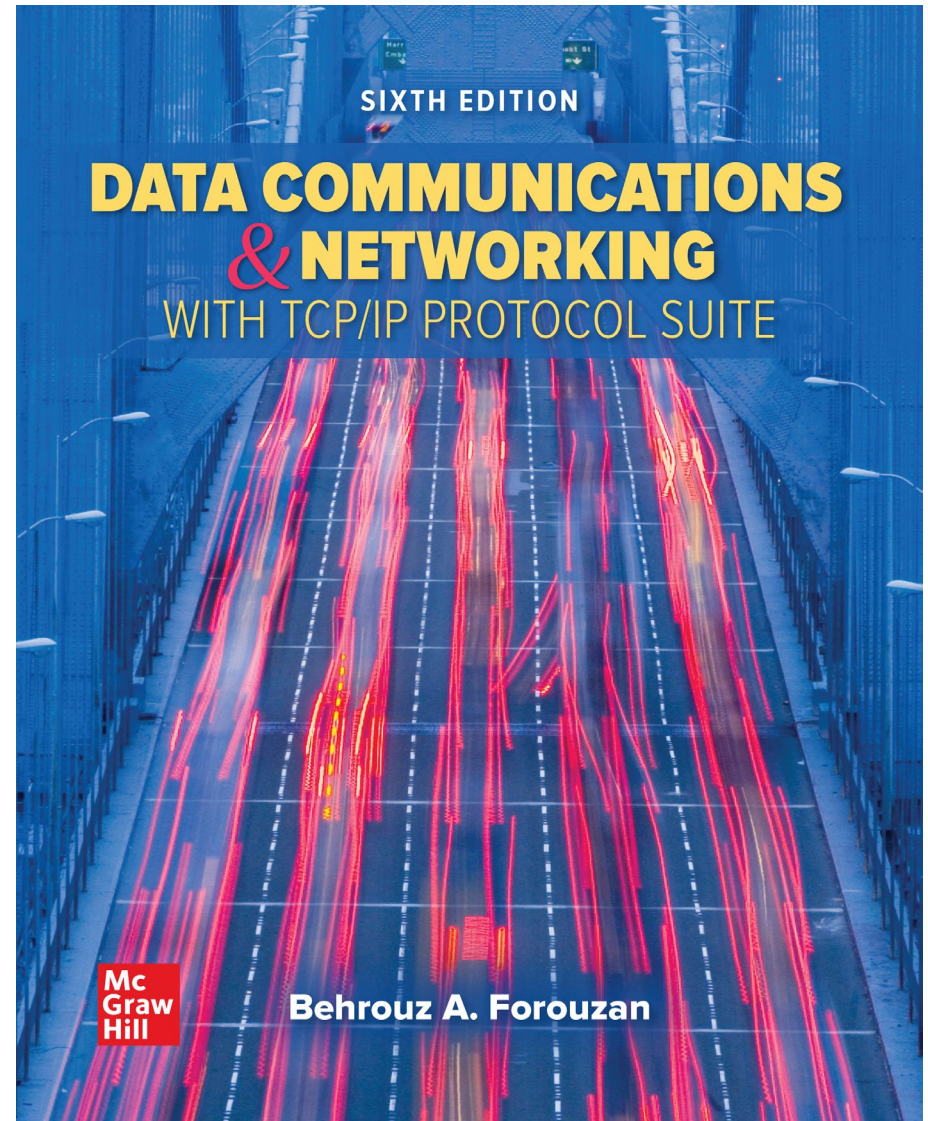


Chapter 13

Network Security

Data Communications and
Networking, With TCP/IP
protocol suite
Sixth Edition
Behrouz A. Forouzan



13-1 INTRODUCTION

We are living in the information age. Information is an asset that has a value like any other asset. As an asset, information needs to be secured from attacks. To be secured, information needs to be hidden from unauthorized access (confidentiality), protected from unauthorized change (integrity), and available to an authorized entity when it is needed (availability).

13.1.1 Security Goals

Let us first discuss three security goals: confidentiality, integrity, and availability.

Confidentiality₁

Confidentiality is probably the most common aspect of information security. We need to protect our confidential information. An organization needs to guard against those malicious actions that endanger the confidentiality of its information. Confidentiality not only applies to the storage of information, it also applies to the transmission of information. When we send a piece of information to be stored in a remote computer or when we retrieve a piece of information from a remote computer, we need to conceal it during transmission.

Integrity

Information needs to be changed constantly. In a bank, when a customer deposits or withdraws money, the balance of her account needs to be changed. Integrity means that changes need to be done only by authorized entities and through authorized mechanisms. Integrity violation is not necessarily the result of a malicious act; an interruption in the system, such as a power surge, may also create unwanted changes in some information.

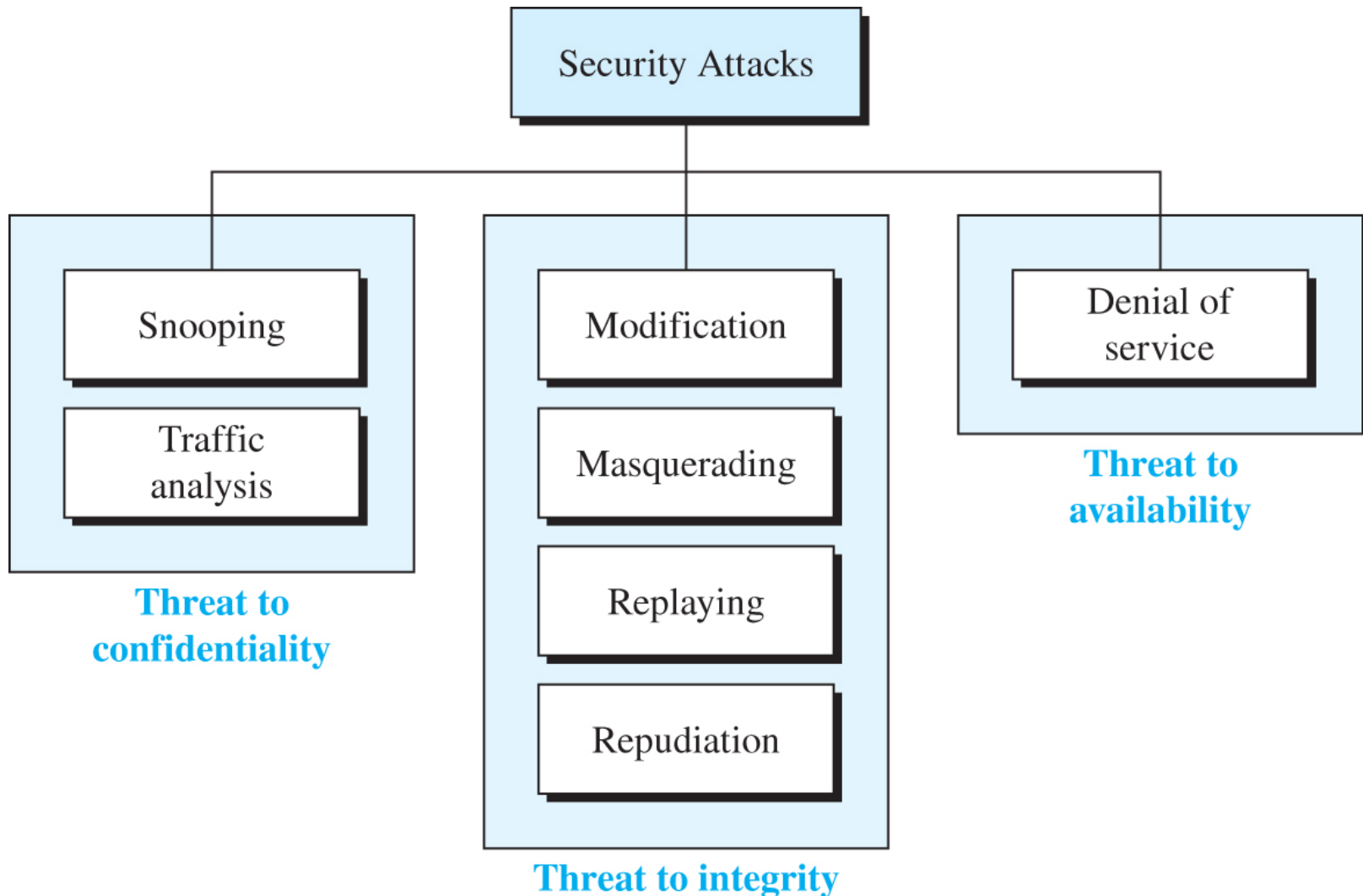
Availability

The third component of information security is availability. The information created and stored by an organization needs to be available to authorized entities. Information is useless if it is not available. Information needs to be constantly changed, which means it must be accessible to authorized entities. The unavailability of information is just as harmful for an organization as the lack of confidentiality or integrity. Imagine what would happen to a bank if the customers could not access their accounts for transactions.

13.1.2 Attacks

Our three goals of security, confidentiality, integrity, and availability, can be threatened by security attacks. Although the literature uses different approaches to categorizing the attacks, we divide them into three groups related to the security goals. Figure 13.1 shows the taxonomy.

Figure 13.1 Taxonomy of attacks with relation to security goals



[Access the text alternative for slide images.](#)

Attacks Threatening Confidentiality

*In general, two types of attacks threaten the confidentiality of information: **snooping** and **traffic analysis***

Attacks Threatening Integrity

*The integrity of data can be threatened by several kinds of attacks: **modification, masquerading, replaying, and repudiation.***

Attacks Threatening Availability

*We mention only one attack threatening availability: **denial of service**.*

13.1.3 Services and Techniques

ITU-T defines some security services to achieve security goals and prevent attacks. Each of these services is designed to prevent one or more attacks while maintaining security goals. The actual implementation of security goals needs some techniques. Two techniques are prevalent today: one is very general (cryptography) and one is specific (steganography).

Cryptography

Some security services can be implemented using cryptography. Cryptography, a word with Greek origins, means “secret writing.” However, we use the term to refer to the science and art of transforming messages to make them secure and immune to attacks. Although in the past cryptography referred only to the encryption and decryption of messages using secret keys, today it is defined as involving three distinct mechanisms: symmetric-key encipherment, asymmetric-key encipherment, and hashing. We will discuss all these mechanisms later in the chapter.

Steganography

Although this chapter and the next are based on cryptography as a technique for implementing security mechanisms, another technique that was used for secret communication in the past is being revived at the present time: steganography. The word steganography, with origins in Greek, means “covered writing,” in contrast with cryptography, which means “secret writing.” Cryptography means concealing the contents of a message by enciphering; steganography means concealing the message itself by covering it with something else. We leave the discussion of steganography to some books dedicated to this topic.

13-2 CONFIDENTIALITY

We now look at the first goal of security, confidentiality. Confidentiality can be achieved using ciphers. Ciphers can be divided into two broad categories: symmetric-key and asymmetric-key.

13.2.1 Symmetric-Key Ciphers

A symmetric-key cipher uses the same key for both encryption and decryption, and the key can be used for bidirectional communication, which is why it is called symmetric. Figure 13.2 shows the general idea behind a symmetric-key cipher.

Traditional Symmetric-Key Ciphers

Traditional ciphers belong to the past. However, we briefly discuss them here because they can be thought of as the components of the modern ciphers. To be more exact, we can divide traditional ciphers into substitution ciphers and transposition ciphers

Figure 13.2 General idea of a symmetric-key cipher

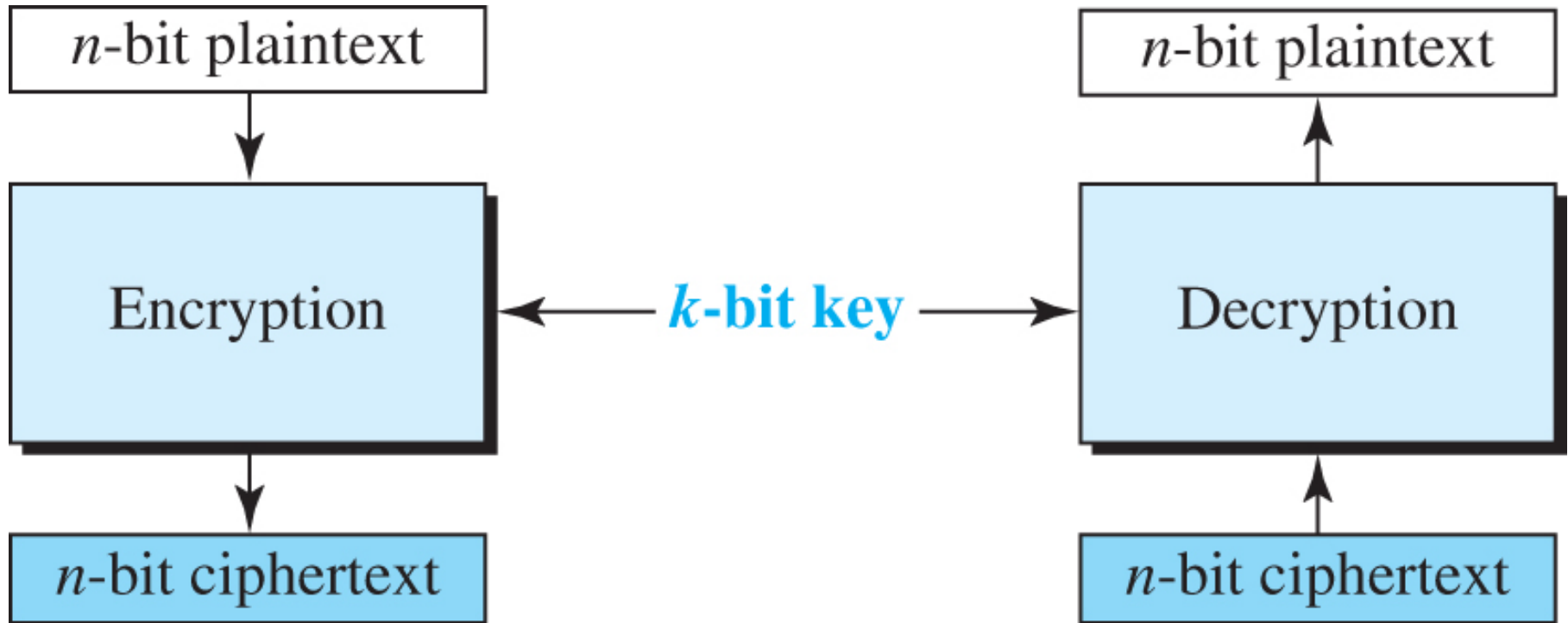


[Access the text alternative for slide images.](#)

Figure 13.3 Symmetric-key encipherment as locking and unlocking with same key



Figure 13.4 A modern block cipher

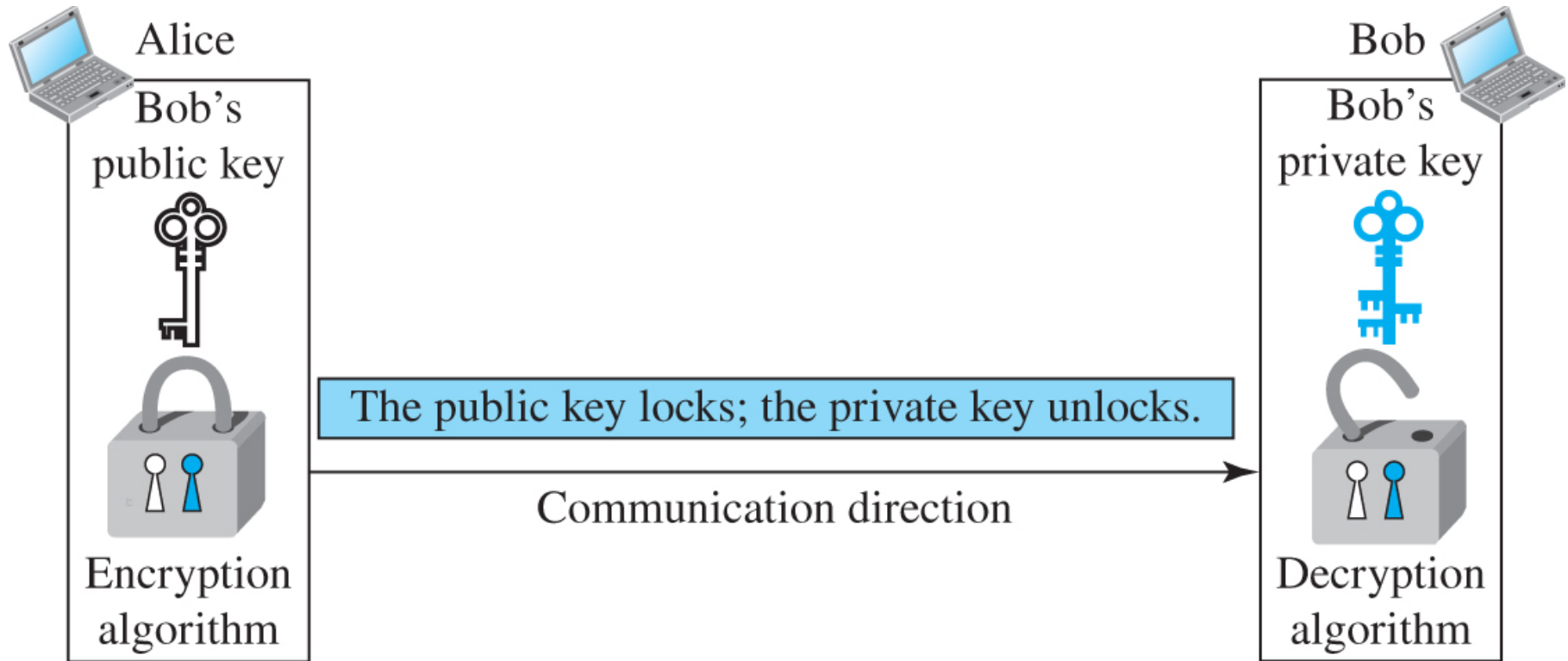


[Access the text alternative for slide images.](#)

13.2.2 Asymmetric-Key Ciphers

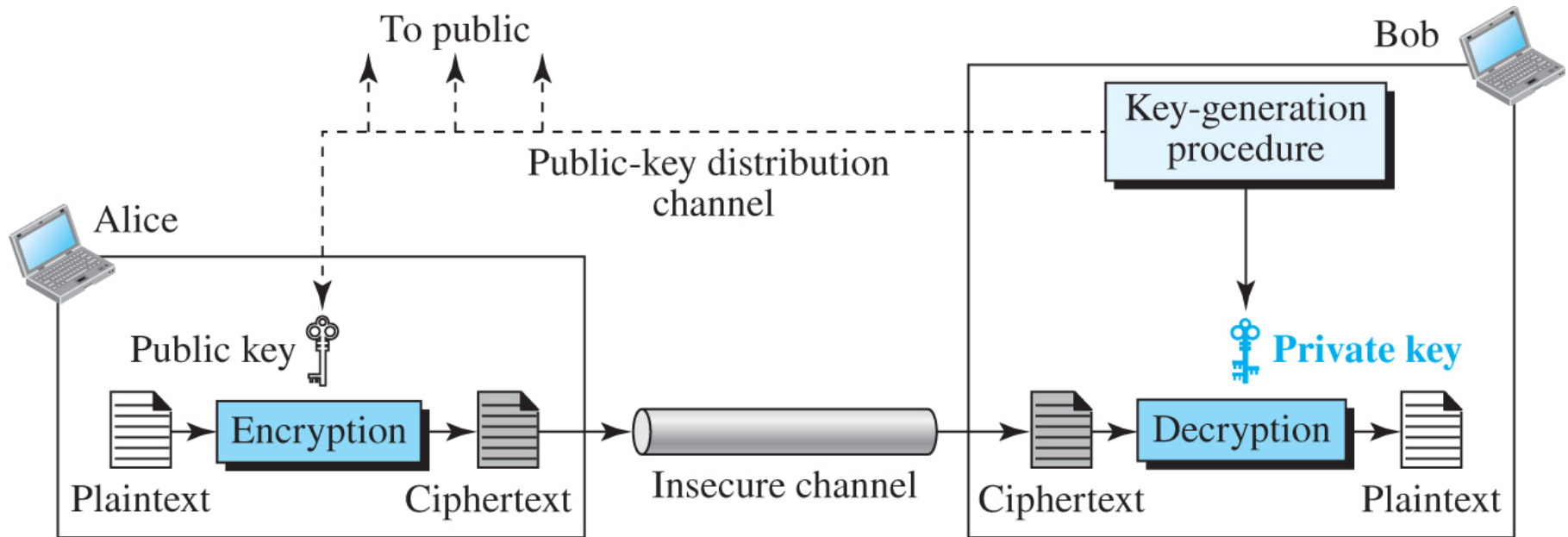
In previous sections we discussed symmetric-key ciphers. In this section, we start the discussion of asymmetric-key ciphers. Symmetric- and asymmetric-key ciphers will exist in parallel and continue to serve the community. We actually believe that they are complements of each other; the advantages of one can compensate for the disadvantages of the other.

Figure 13.5 Locking and unlocking in asymmetric-key cryptosystem



[Access the text alternative for slide images.](#)

Figure 13.6 General idea of asymmetric-key cryptosystem



[Access the text alternative for slide images.](#)

13-3 OTHER ASPECTS OF SECURITY

The cryptography systems that we have studied so far provide confidentiality. However, in modern communication, we need to take care of other aspects of security, such as integrity, message and entity authentication, nonrepudiation, and key management. We briefly discuss these issues in this section.

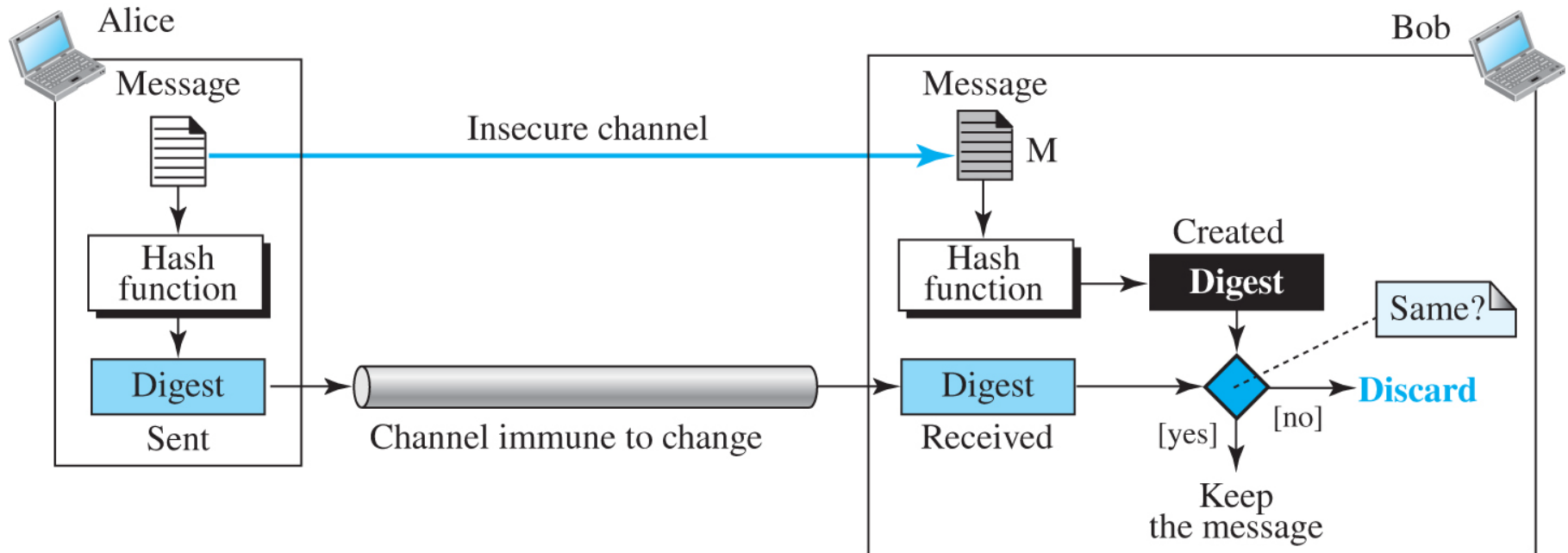
13.3.1 Message Integrity

There are occasions where we may not even need secrecy but instead must have integrity: the message should remain unchanged. For example, Alice may write a will to distribute her estate upon her death. The will does not need to be encrypted. After her death, anyone can examine the will. The integrity of the will, however, needs to be preserved. Alice does not want the contents of the will to be changed.

Message and Message Digest

One way to preserve the integrity of a document is through the use of a fingerprint. If Alice needs to be sure that the contents of her document will not be changed, she can put her fingerprint at the bottom of the document. Eve cannot modify the contents of this document or create a false document because she cannot forge Alice's fingerprint. To ensure that the document has not been changed, Alice's fingerprint on the document can be compared to Alice's fingerprint on file. If they are not the same, the document is not from Alice. The electronic equivalent of the document and fingerprint pair is the message and digest pair.

Figure 13.7 Message and digest



[Access the text alternative for slide images.](#)

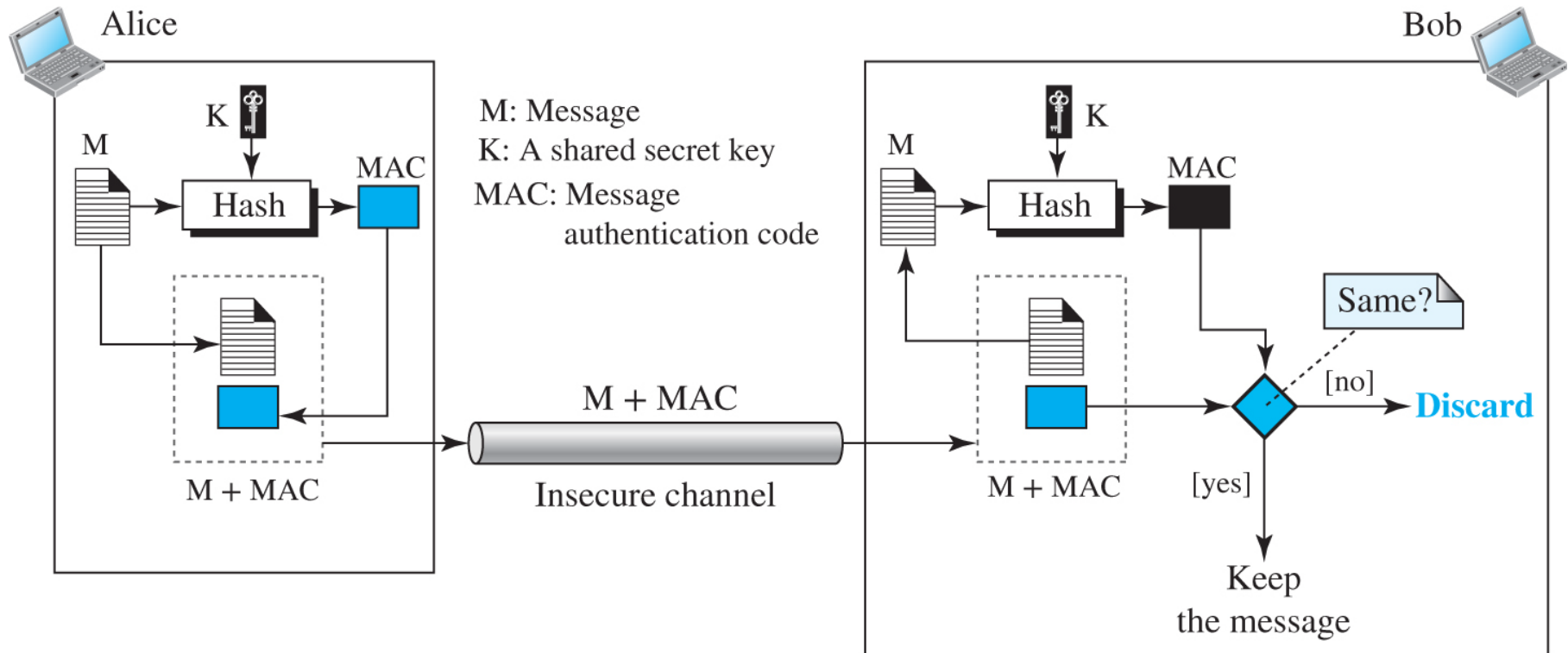
Hash Functions

A cryptographic hash function takes a message of arbitrary length and creates a message digest of fixed length. All cryptographic hash functions need to create a fixed-size digest out of a variable-size message. Creating such a function is best accomplished using iteration. Instead of using a hash function with variable-size input, a function with fixed-size input is created and is used a necessary number of times. The fixed-size input function is referred to as a compression function. It compresses an n -bit string to create an m -bit string where n is normally greater than m . The scheme is referred to as an iterated cryptographic hash function.

13.3.2 Message Authentication

A digest can be used to check the integrity of a message—that the message has not been changed. To ensure the integrity of the message and the data origin authentication—that Alice, not somebody else, is the originator of the message—we need to include a secret shared by Alice and Bob (that Eve does not possess) in the process; we need to create a message authentication code (MAC). Figure 13.8 shows the idea.

Figure 13.8 Message authentication code



[Access the text alternative for slide images.](#)

13.3.3 Digital Signature

Another way to provide message integrity and message authentication (and some more security services, as we will see shortly) is a digital signature. A MAC uses a secret key to protect the digest; a digital signature uses a pair of private-public keys.

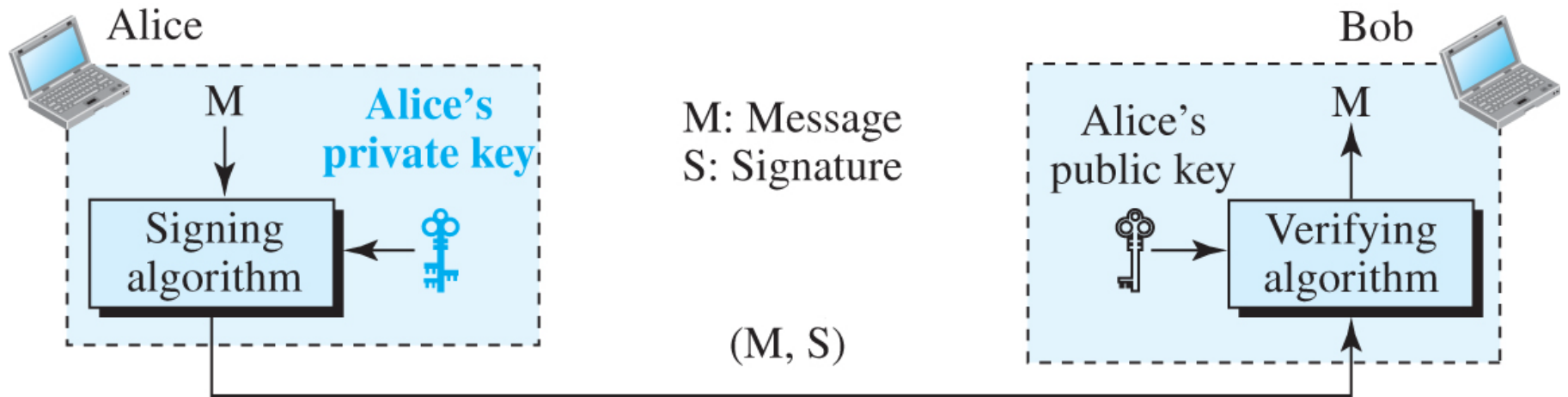
Comparison₁

Let us begin by looking at the differences between conventional signatures and digital signatures.

Process 1

Figure 13.9 shows the digital signature process. The sender uses a signing algorithm to sign the message. The message and the signature are sent to the receiver. The receiver receives the message and the signature and applies the verifying algorithm to the combination. If the result is true, the message is accepted; otherwise, it is rejected.

Figure 13.9 Digital signature process

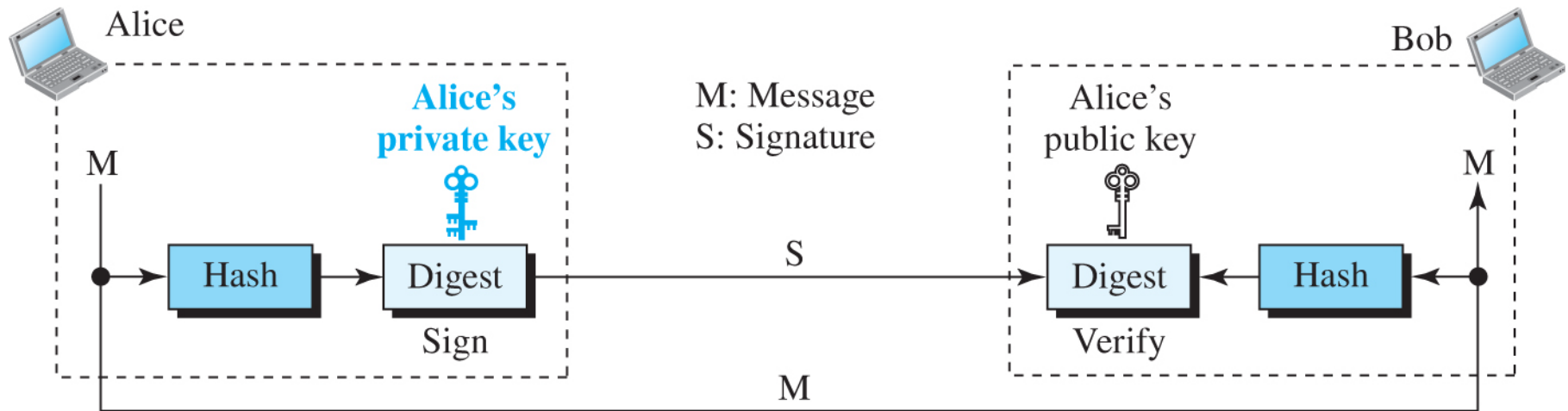


[Access the text alternative for slide images.](#)

Process 2

Figure 13.10 shows the digital signature process. The sender uses a signing algorithm to sign the message. The message and the signature are sent to the receiver. The receiver receives the message and the signature and applies the verifying algorithm to the combination. If the result is true, the message is accepted; otherwise, it is rejected.

Figure 13.10 Signing the digest

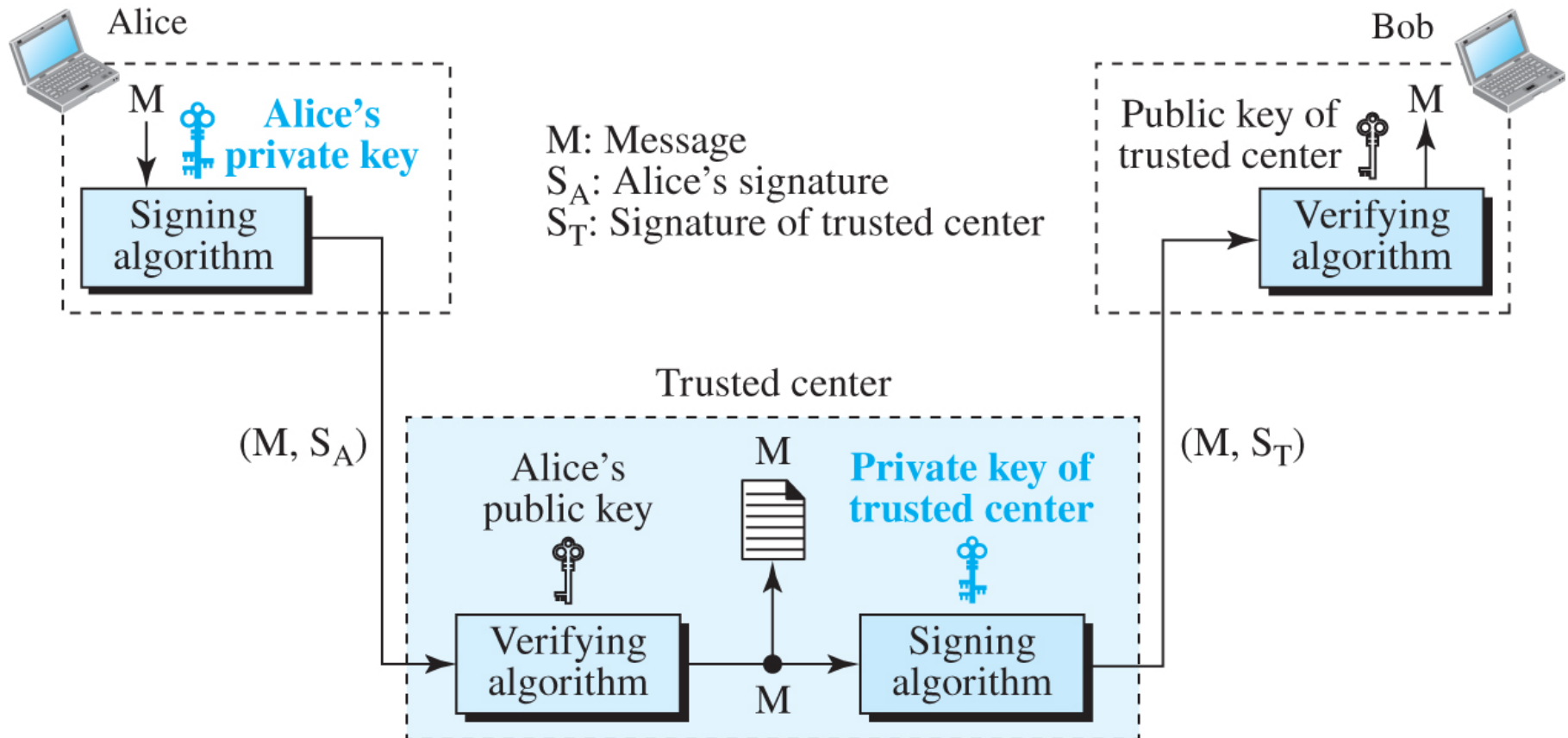


[Access the text alternative for slide images.](#)

Services₁

We discussed several security services in the beginning of the chapter including message confidentiality, message authentication, message integrity, and non-repudiation. A digital signature can directly provide the last three; for confidentiality we still need encryption/decryption.

Figure 13.11 Using a trusted center for non-repudiation



[Access the text alternative for slide images.](#)

13.3.4 Entity Authentication

Entity authentication is a technique designed to let one party verify the identity of another party. An entity can be a person, a process, a client, or a server. The entity whose identity needs to be proven is called the claimant; the party that tries to verify the identity of the claimant is called the verifier.

Entity versus Message Authentication

There are two differences between entity authentication and message authentication (data-origin authentication).

- 1. Message authentication (or data-origin authentication) might not happen in real time; entity authentication does.*
- 2. Message authentication simply authenticates one message. Entity authentication authenticates the claimant for the entire duration of a session.*

13-4 SAMPLE OF APPLICATION-LAYER SECURITY

This section discusses an example protocol providing security services for e-mails: Pretty Good Privacy (PGP).

13.4.1 E-mail Security

Sending an e-mail is a one-time activity. The nature of this activity is different from those we saw in the two previous sections: SSL or IPSec. In those protocols, we assume that the two parties create a session between themselves and exchange data in both directions. In e-mail, there is no session. Alice and Bob cannot create a session. Alice sends a message to Bob; sometime later, Bob reads the message and may or may not send a reply.

Cryptographic Algorithms

- *If e-mail is a one-time activity, how can the sender and receiver agree on a cryptographic algorithm to use for e-mail security? If there is no session and no handshaking to negotiate the algorithms for encryption/decryption and hashing, how can the receiver know which algorithm the sender has chosen for each purpose?*
- *To solve the problem, the protocol defines a set of algorithms for each operation that the user used in his/her system. Alice includes the names (or identifiers) of the algorithms she has used in the e-mail. When Alice sends a message to Bob, she includes the corresponding identifiers for DES and MD5 in her message. Bob receives the message and extracts the identifiers first.*

Cryptographic Secrets

The same problem for the cryptographic algorithms applies to the cryptographic secrets (keys). If there is no negotiation, how can the two parties establish secrets between themselves? The e-mail security protocols today require that encryption/decryption be done using a symmetric-key algorithm and a one-time secret key sent with the message. Alice can create a secret key and send it with the message she sends to Bob. To protect the secret key from interception by Eve, the secret key is encrypted with Bob's public key. In other words, the secret key itself is encrypted.

Certificates

One more issue needs to be considered before we discuss any e-mail security protocol in particular. It is obvious that some public-key algorithms must be used for e-mail security. For example, we need to encrypt the secret key or sign the message. To encrypt the secret key, Alice needs Bob's public key; to verify a signed message, Bob needs Alice's public key. So, for sending a small authenticated and confidential message, two public keys are needed. How can Alice be assured of Bob's public key, and how can Bob be assured of Alice's public key? Each e-mail security protocol has a different method of certifying keys.

13.4.2 Pretty Good Privacy (PGP)

The first protocol discussed in this section is called Pretty Good Privacy (PGP). PGP was invented by Phil Zimmermann to provide e-mail with privacy, integrity, and authentication. PGP can be used to create secure e-mail messages.

Scenarios

Let us first discuss the general idea of PGP, moving from a simple scenario to a complex one. We use the term “Data” to show the message prior to processing.

Figure 13.12 A plaintext message

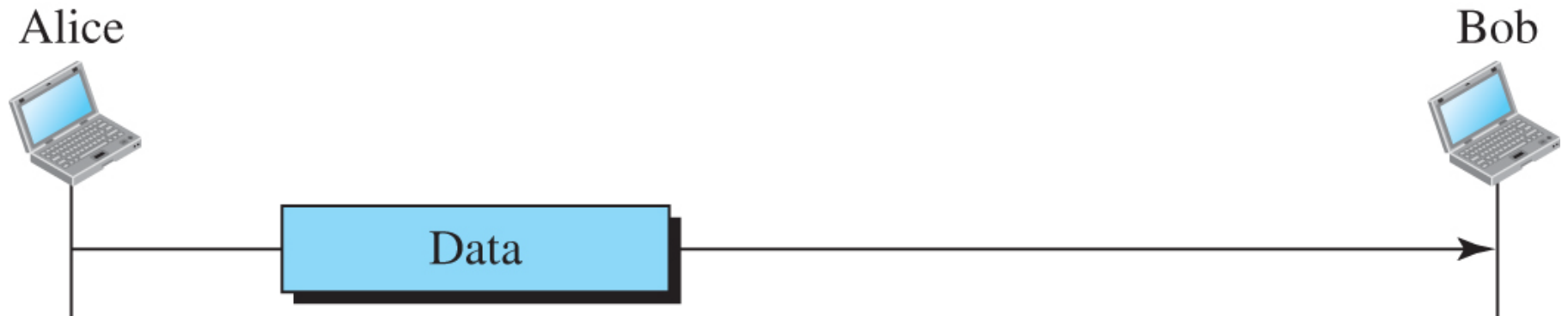
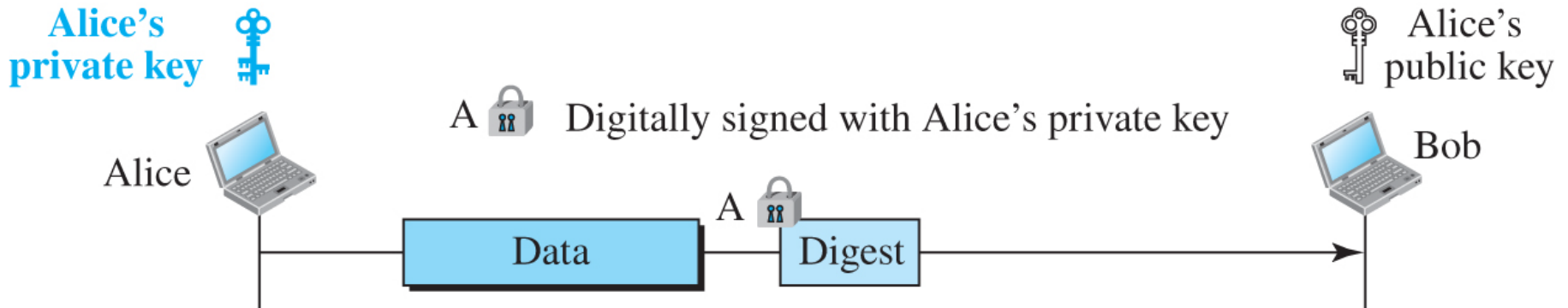
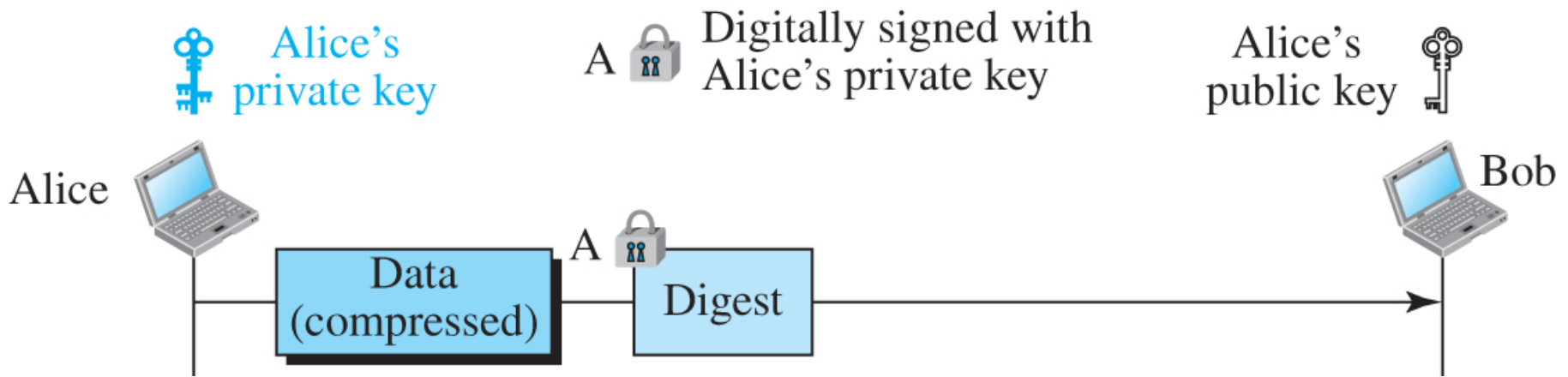


Figure 13.13 An authenticated message



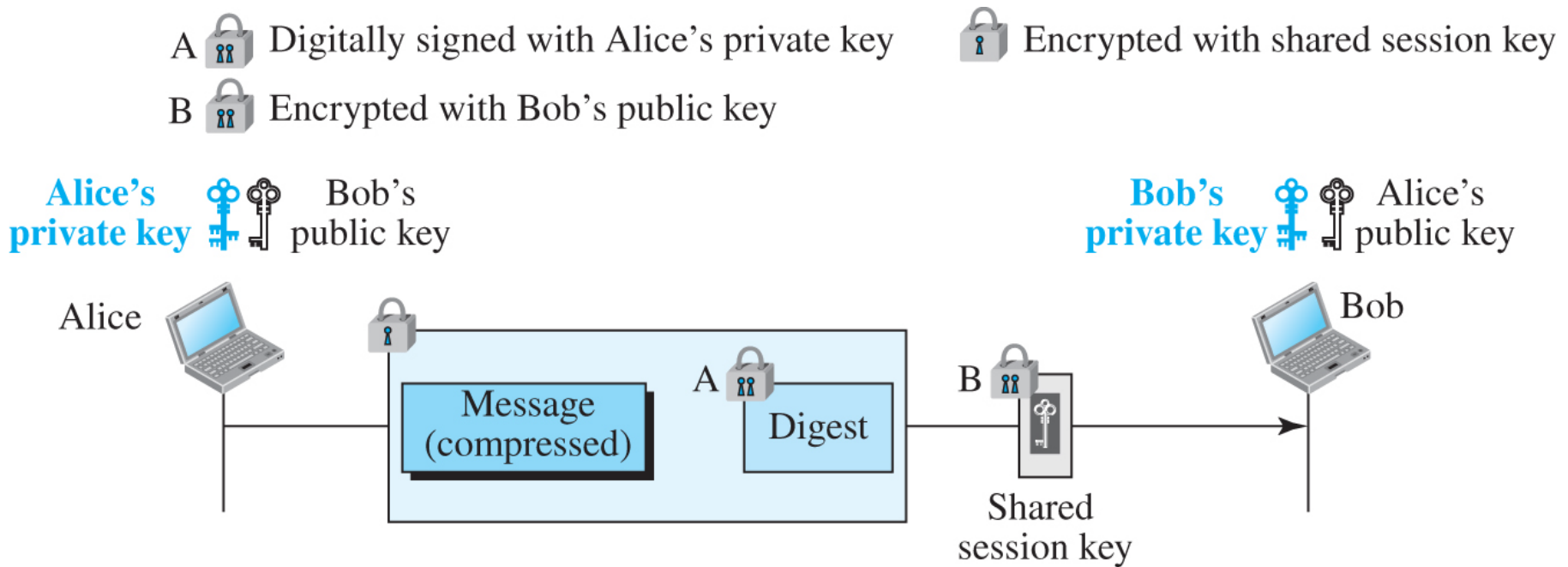
[Access the text alternative for slide images.](#)

Figure 13.14 A compressed message



[Access the text alternative for slide images.](#)

Figure 13.15 A confidential message

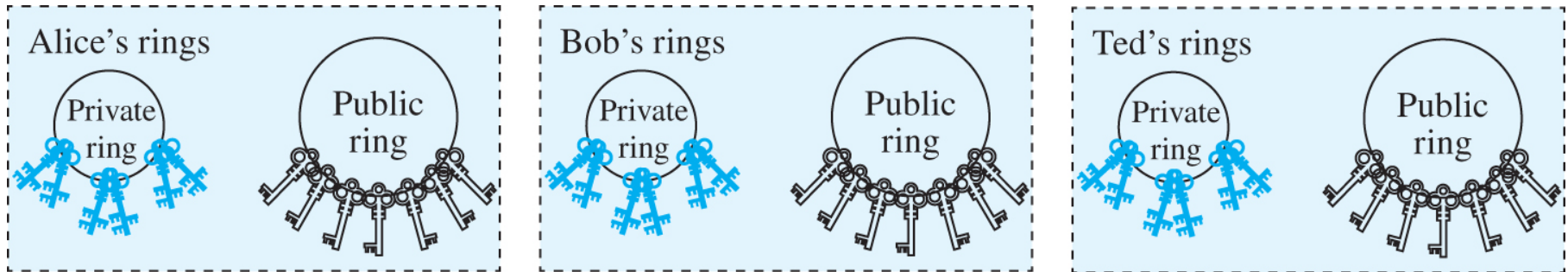


[Access the text alternative for slide images.](#)

Key Rings

In all previous scenarios, we assumed that Alice needs to send a message only to Bob. That is not always the case. Alice may need to send messages to many people; she needs key rings. In this case, Alice needs a ring of public keys, with a key belonging to each person with whom Alice needs to correspond (send or receive messages). In addition, the PGP designers specified a ring of private/public keys. One reason is that Alice may wish to change her pair of keys from time to time. Another reason is that Alice may need to correspond with different groups of people (friends, colleagues, and so on). Alice may wish to use a different key pair for each group.

Figure 13.16 Key rings in PGP



[Access the text alternative for slide images.](#)

Applications of PGP

PGP has been extensively used for personal e-mails. It will probably continue to be.



Because learning changes everything.®

www.mheducation.com